

Software Design Description (SDD)

Project Name: InnoTech internal services

Institute: Holon Institute of Technologies

Date: _____

Team Members:

- Supervisor: Roi Zimon
- Student 1: [Name] - [ID]
- Student 2: [Name] - [ID]
- Student 3: [Name] - [ID]
- Student 4: [Name] - [ID]

1. General Description & Methodology

1.1 The Problem

In the current cyber landscape, standard defensive measures (Firewalls, WAFs) are reactive and static. They block known threats but fail to gather intelligence on new attack vectors. Attackers can scan networks indefinitely until they find a vulnerability, while defenders have zero visibility into the attacker's intent or tools before a breach occurs.

1.2 The Solution

We propose an "Active Deception Platform" (High-Interaction Honeypot). Instead of simply blocking suspicious traffic, the system identifies potential threats and silently reroutes them to a realistic "Decoy Environment." This allows the organization to:

1. **Waste the attacker's time** (via infinite loops and fake errors).
2. **Gather intelligence** (fingerprinting IP, tools, and behavior).
3. **Exhaust attacker resources** (via Data Bombs).

1.3 Project Goals

- **Deception:** Successfully route 100% of flagged traffic to the decoy layer without the user realizing they have been moved.
- **Resource Exhaustion:** Implement specific traps (Data Bomb) that consume at least 500MB of attacker bandwidth per trigger.
- **Analysis:** Provide a real-time Admin Dashboard that maps attacker locations and assigns a "Risk Score" based on their actions.

1.3.1 Detailed Requirements

Functional Requirements (FR):

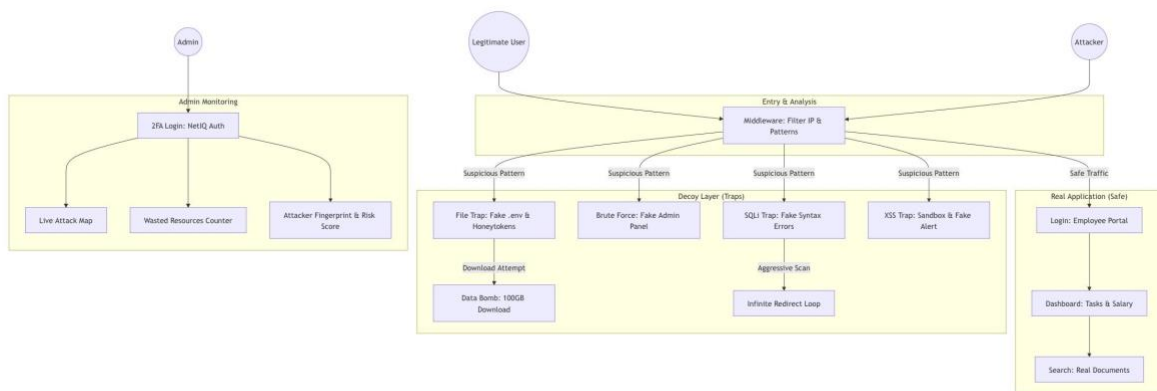
- FR-01: The system must differentiate between legitimate users and attackers based on IP reputation and request patterns.
- FR-02 (The Trap): The system must allow the 10th brute-force attempt to succeed, redirecting the attacker to the Decoy Dashboard.
- FR-03 (Data Bomb): Accessing /backup.sql must trigger a continuous stream of zero-byte data to exhaust attacker resources.
- FR-04 (Monitoring): The Admin Dashboard must display attacker geolocation in real-time using WebSocket.

Non-Functional Requirements (NFR):

- NFR-01 (Security): The Admin Dashboard must be protected by NetIQ 2FA.
- NFR-02 (Performance): The "Decoy" logic must not add more than 50ms latency to legitimate user requests.
- NFR-03 (Isolation): Attacker logs must be stored in a separate collection from legitimate user data.

1.4 Functional Requirements (Abstract View)

The system distinguishes between two primary actors: the Legitimate User and the Attacker. The Use Case diagram below illustrates how the Middleware filters these actors and which specific traps are triggered by suspicious actions.



Key Scenarios:

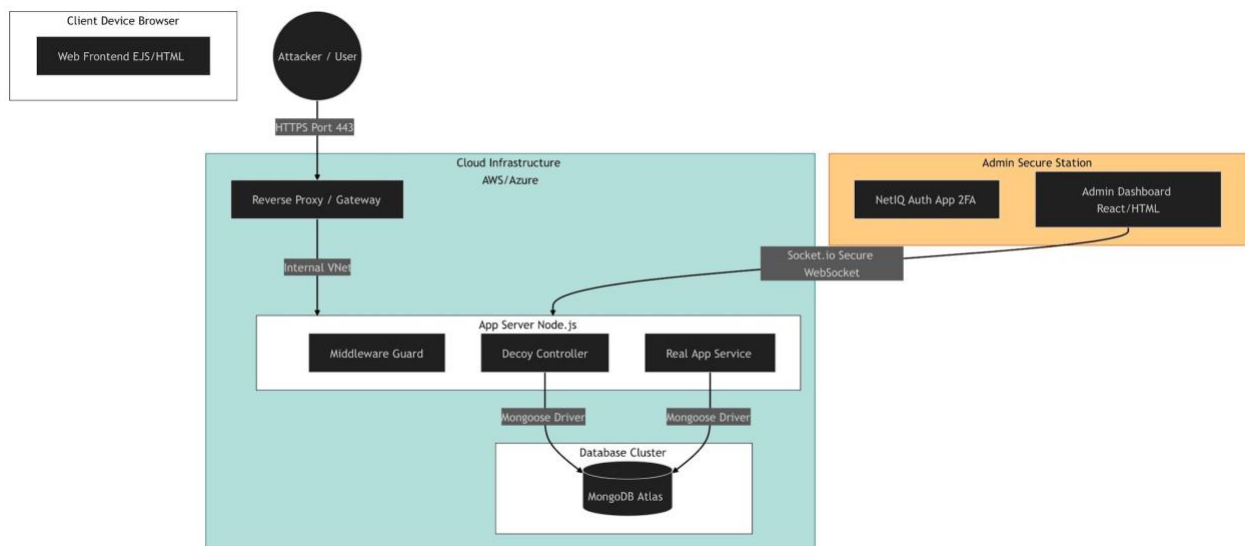
- **Legitimate User:** Logs in via valid credentials → Accesses "Real Application" (Salary, Tasks).

- **Attacker:** Performs suspicious action (SQLi) → Routed to "Decoy Layer" → Triggers specific traps (Fake Admin Panel, Data Bomb).

2. System Domain & Architecture (Physical View)

2.1 System Domain

The system operates in a Cloud-based Domain. It is designed as a secure web application that acts as a gatekeeper for an internal corporate network. The infrastructure is split into a "Public Zone" (Reverse Proxy) and a "Secure Zone" (Database and Admin Dashboard).



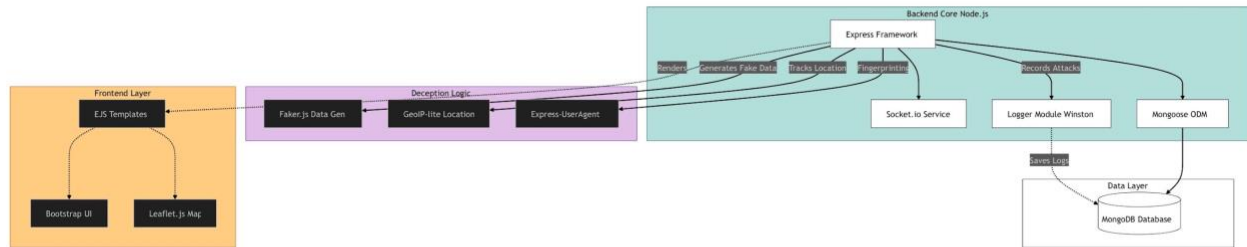
2.2 Component Description

- **Reverse Proxy / Gateway:** The entry point for all traffic. It anonymizes the backend server and performs the initial "IP Reputation Check."
- **App Server (Node.js):** The core processing unit. It hosts two distinct controllers: the RealController (for employees) and the DecoyController (for attackers).
- **Database Cluster (MongoDB Atlas):** A NoSQL database chosen for its flexibility in storing unstructured attack logs and binary data for the honeypot.
- **Admin Secure Station:** A standalone client protected by 2FA (NetIQ), connecting via a secure WebSocket channel to receive live threat telemetry.

3. Main Modules (Development View)

3.1 Module Breakdown

The software is constructed using a Modular Monolith architecture to ensure the deceptive logic does not interfere with the real application's stability.

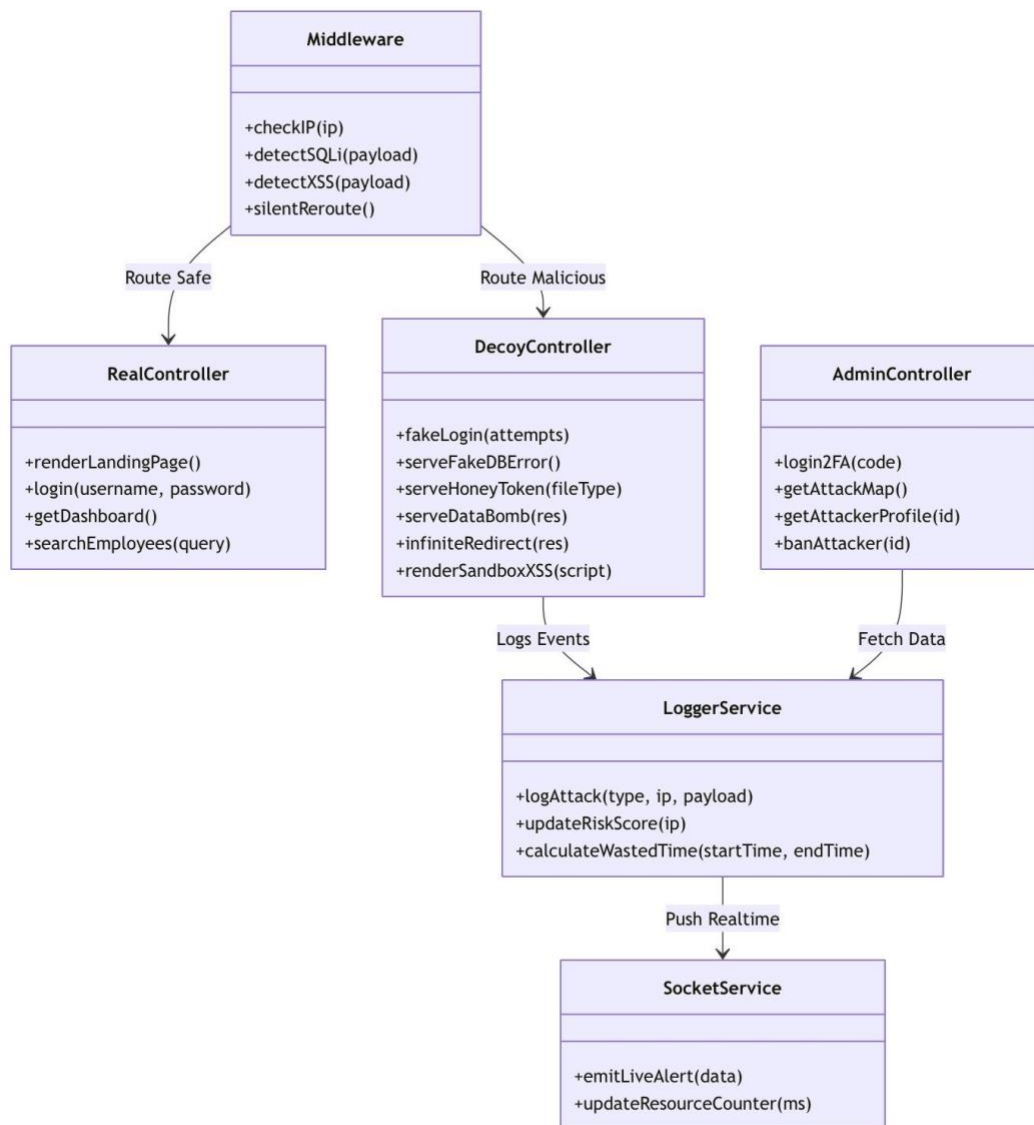


3.2 Key Libraries & Modules

- **Deception Module (Faker.js):** Dynamically generates fake user profiles, emails, and salary data. This ensures the honeypot looks "alive" and different for every attacker.
- **Logger Module (Winston):** A custom logging service that tracks specific metrics: wasted_time_ms (how long the attacker was trapped) and bytes_sent (bandwidth consumption).
- **Fingerprinting Module (Express-UserAgent):** Extracts detailed device data (OS, Browser, Screen Resolution) to create a unique fingerprint for every intruder.

3.3 Class Structure (Logical View)

The internal code logic is organized into Controllers and Services to ensure clean separation between the real application and the deception logic.



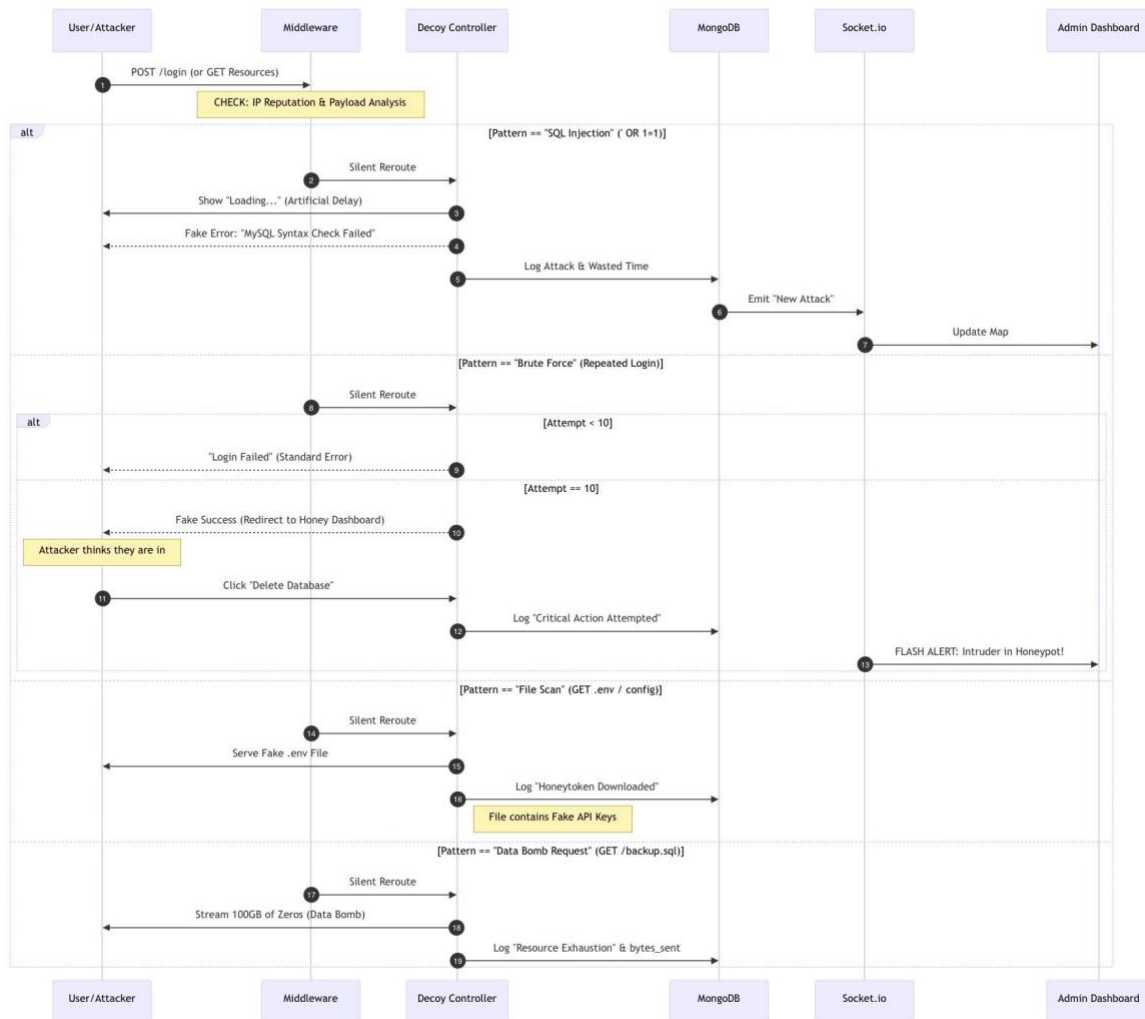
Class Descriptions:

- **DecoyController:** Contains the methods for all traps (e.g., serveDataBomb(), infiniteRedirect()). It handles the malicious requests forwarded by the middleware.
- **AdminController:** Manages the secure dashboard, including the banAttacker() method and fetching the live attack map.
- **LoggerService:** A shared service used by all controllers to standardize how attacks are recorded in the MongoDB database.

4. Algorithms & Process Logic (Process View)

4.1 The "Silent Reroute" Algorithm

The system uses a custom middleware algorithm to decide traffic flow. Unlike a firewall that returns 403 Forbidden, this algorithm returns 200 OK but serves a different HTML template.



4.2 Specific Trap Algorithms

1. The "10th Attempt" Brute Force Logic:

- Logic: If login_attempts < 9, return generic error.
- Logic: If login_attempts == 10, return Fake Success.
- Purpose: Encourages the attacker to believe their dictionary attack worked, keeping them engaged in the trap longer.

2. The Data Bomb (Resource Exhaustion):

- Trigger: GET /backup.sql

- Algorithm: The server initiates a file stream with Content-Length: 100GB. It writes chunks of zero-byte data to the response stream continuously.
- Goal: Crash the attacker's download tool or exhaust their disk space.

5. Data Design (Logical View)

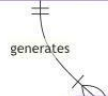
5.1 Database Schema

The data layer is designed to support high-velocity write operations for logging attacks.

ADMIN_USER		
ObjectId	_id	PK
string	username	
string	password_hash	
string	secret_key_2fa	
datetime	last_login	



ATTACKER_PROFILE			
ObjectId	_id	PK	
string	ip_address		
string	isp_provider		
string	geo_location		
string	browser_type		
string	os_system		
string	screen_resolution		
int	risk_score		
int	login_attempts_count		Counter for the 10th try logic
string	status		Active / Banned
datetime	first_seen		



REAL_EMPLOYEE		
ObjectId	_id	PK
string	username	
string	full_name	
string	phone_number	
string	address	
string	department	
string	email	



ATTACK_EVENT			
ObjectId	_id	PK	
ObjectId	attacker_id	FK	
string	trap_type		
string	payload_used		
int	wasted_time_ms		
int	bytes_sent		For Data Bomb tracking
string	target_url		
datetime	timestamp		



HONEY_TOKEN		
ObjectId	_id	PK
string	token_key	
string	source_file	
boolean	is_triggered	
datetime	triggered_at	

5.2 Entity Descriptions

- **ATTACKER_PROFILE:** The main identity record. Includes risk_score (calculated based on trap triggers) and status (Active/Banned).
- **ATTACK_EVENT:** The transaction log. Links to the Profile and records the specific payload_used (e.g., the exact SQL code the attacker tried).
- **HONEY_TOKEN:** A table containing the fake API keys. If a key from this table is ever used to query the API, the system triggers an immediate "Critical Alert."

6. Interfaces (UI & API)

6.1 API Specifications

The backend exposes a REST API used by the frontend client.

Method	Endpoint	Access	Trap Logic
POST	/api/login	Public	Brute Force Trap: Returns fake success on 10th try.
GET	/api/dashboard	Private	Decoy: Returns fake salary data generated by Faker.js.
GET	/backup.sql	Public	Data Bomb: Streams 100GB of dummy data.
GET	/admin/map	Secure	Returns GeoJSON of active threats for the map.

6.2 User Interface Mockups

The UI is designed to look indistinguishable from a legitimate corporate tool to maintain the illusion.

```
+-----+
| [ InnoTech Enterprise Portal ] |
+-----+
|
|   +-----+
|   | Username: [           ] |
|   +-----+
|
|   +-----+
|   | Password: [           ] |
|   +-----+
|
|   [          SIGN IN (Delay: 3s)          ]
|
|   ( ) Remember Me           Forgot Password?
|
+-----+
```

```
+-----+
| InnoTech Admin | [ Search Users... (SQLi Trap) ] |
+-----+
| [ Side Menu ] | DASHBOARD OVERVIEW |
| - HR Data    | |
| - Finance    | |
| - Settings   | |
|              | |
|              | +-----+
|              | | CRITICAL BACKUP |
|              | | [ DOWNLOAD DB (100GB) ] |
|              | | * Click triggers Data Bomb |
|              | +-----+
|              |
|              | +-----+
|              | | Employee Directory |
|              | | - John Doe (Fake) |
|              | | - Jane Smith (Fake) |
|              | +-----+
|              |
+-----+
```

```
+-----+
| ADMIN MONITOR - SECURE CHANNEL (Socket.io) |
+-----+
| LIVE MAP (GeoIP) | REAL-TIME LOGS |
|                  |                |
|      .   (X)      | > [14:02] SQLi Detected |
|      / \         | Source: 192.168.1.5   |
|     (X)  .        | Action: Delay + Log   |
|                  |                |
| (X) = Active Attacker | > [14:03] File Scan |
|                  | Source: 10.0.0.8     |
+-----+
| STATS: |
| [ Wasted Time: 45m ] [ Bandwidth: 3.2GB ] |
| [ Active Bans: 12 ]  [ BAN ATTACKER      ] |
+-----+
```

(Login, Fake Dashboard, Admin Map: We'll change it to a screenshots later)

7. Security & Deployment

- **Network Isolation:** The "Decoy" and "Real" controllers run on the same server but use different database connections to prevent data leakage.
- **Authentication:** The Admin Dashboard is protected by NetIQ 2FA, ensuring that even if the honeypot is compromised, the monitoring station remains secure.